

Manual 35 — Singapore AI & Privacy Governance

Controlled Implementation

****Language:**** English

****Controlled baseline:**** Singapore PDPA/PDPC privacy requirements plus current Singapore Traditional AI, Generative AI, AI Verify, and Agentic AI governance resources, verified 2026-08-31.

****Boundary:**** Binding law/regulation, regulator guidance/enforcement, voluntary AI governance/testing resources, sector overlays, and organisation-specific practices remain distinct. This manual is implementation guidance, not legal advice, regulatory approval, or certification.

Chapter 01 — Purpose, Scope, and Controlled-Source Hierarchy

Use the PDPA and applicable regulations as the binding privacy layer. Treat PDPC advisory material, enforcement decisions, IMDA/PDPC AI frameworks, AI Verify resources, sector rules, contracts, and internal procedures according to their actual legal status. Maintain a dated source register and escalate conflicts or unclear applicability to qualified counsel or the relevant regulator-facing function.

Evidence should include the approved scope, source hierarchy, applicability assumptions, source-verification date, responsible owners, and a record of material changes that require re-review.

Chapter 02 — Singapore Regulatory and Governance Ecosystem

Map the roles of PDPC, IMDA, sector regulators, contractual counterparties, and internal governance bodies. A single AI or privacy use case may be affected by several layers, so accountability should identify which requirement comes from statute, regulation, advisory guidance, sector expectation, contract, or voluntary governance practice.

Maintain a regulatory map, owner matrix, sector-overlay register, and escalation route for legal or supervisory interpretation.

Chapter 03 — PDPA Applicability, Exclusions, and Organisation Roles

Document whether the PDPA applies to the organisation, activity, data, and relationship under review. Preserve distinctions involving organisations, individuals acting personally or domestically, public-agency contexts, employee data, business contact information, data intermediaries, and other statutory or regulatory exceptions.

Evidence should show the applicability analysis, processing context, role determination, exceptions relied on, and review approval.

Chapter 04 — Accountability Obligation and Data Protection Officer Governance

Establish accountable privacy governance with a designated Data Protection Officer and clear executive oversight. Define decision rights, reporting lines, resourcing, policy ownership, complaint handling, regulatory communications, and periodic management review without assuming that DPO appointment alone demonstrates compliance.

Maintain DPO appointment records, governance charters, policy approvals, management reports, issue logs, and evidence of corrective action.

Chapter 05 — Notification, Consent, and Consent-Withdrawal Controls

Design collection, use, and disclosure processes so individuals receive appropriate purpose information and consent is obtained where required. Support withdrawal of consent with reasonable notice while identifying legitimate exceptions or alternative statutory bases where applicable.

Keep notices, consent records, withdrawal requests, system changes, exception decisions, and communication evidence traceable to the affected processing activity.

Chapter 06 — Purpose Limitation and Appropriate-Purpose Reasoning

Evaluate whether each collection, use, or disclosure is for a purpose a reasonable person would consider appropriate in the circumstances and is consistent with the organisation's stated purposes and lawful basis. New AI-enabled secondary uses should not inherit permission automatically from the original collection purpose.

Maintain purpose assessments, change approvals, use-case justifications, stakeholder review, and records of rejected or modified purposes.

Chapter 07 — Accuracy and Decision-Impact Controls

Apply proportionate accuracy and completeness controls when personal data is likely to be used to make decisions affecting individuals or disclosed to other organisations. For AI-supported decisions, test data quality, freshness, representativeness, and material error pathways appropriate to the decision impact.

Evidence should include data-quality rules, validation results, correction mechanisms, decision-impact assessments, and remediation records.

Chapter 08 — Protection Obligation and Reasonable Security Arrangements

Implement reasonable administrative, technical, and physical safeguards appropriate to the sensitivity, volume, use, and threat environment of personal data. AI systems should be included in identity, access, secure configuration, logging, vulnerability management, data protection, resilience, and incident-response controls.

Maintain security risk assessments, control mappings, test results, access reviews, remediation records, and management acceptance of residual risk.

Chapter 09 — Retention Limitation and Defensible Disposal

Stop retaining personal data, or remove the means by which it can be associated with individuals, when retention is no longer necessary for legal or business purposes. AI training, evaluation, logs, prompts, embeddings, backups, and derived datasets require explicit retention treatment rather than indefinite technical default.

Maintain retention schedules, legal-hold rules, disposal evidence, exception approvals, and periodic checks for orphaned data stores.

Chapter 10 — Transfer Limitation and Overseas Data-Transfer Governance

Before transferring personal data outside Singapore, determine the applicable transfer mechanism and whether the receiving environment provides a standard of protection comparable to the PDPA as required by current rules. Separate legal transfer requirements from vendor security due diligence and commercial convenience.

Evidence should include transfer assessments, contractual safeguards, recipient due diligence, data-flow maps, exceptions, and periodic reassessment.

Chapter 11 — Access and Correction Rights Operations

Create intake, identity-verification, search, review, response, correction, exception, and escalation procedures for access and correction requests. Systems using AI-derived or replicated personal data should be included in discovery and correction propagation where applicable.

Maintain request logs, response decisions, identity checks, correction actions, disclosure histories, exception rationale, and completion metrics.

Chapter 12 — Mandatory Data-Breach Assessment and Notification

Use a documented breach-assessment process tied to current PDPA/PDPC criteria for significant harm and/or significant scale. Once a breach is determined notifiable, notify the PDPC as soon as practicable and no later than three calendar days after the determination, and address affected-individual notification where required.

Preserve incident facts, assessment timing, threshold analysis, determination authority, notification records, communications, remediation, and lessons learned.

Chapter 13 — Data Intermediaries and Contractual Responsibilities

Identify when a party acts as a data intermediary and allocate responsibilities contractually and operationally. Outsourcing does not eliminate the organisation's governance duties; contracts should align instructions, security, breach escalation, subcontracting, retention, transfers, audit evidence, and termination handling.

Maintain role matrices, contracts, processor inventories, due diligence, monitoring evidence, breach-notification obligations, and exit records.

Chapter 14 — Data Portability Change-Watch and Activation Control

Treat the Data Portability Obligation as non-operative until the necessary regulations take effect. Maintain a formal change-watch so the organisation can assess scope, technical format, exceptions, timelines, and operational impact when activation occurs rather than prematurely presenting portability as a current legal duty.

Evidence should include the source-watch record, legal-status confirmation, readiness assessment, implementation backlog, and activation decision.

Chapter 15 — Data Inventory, Classification, Lineage, and Processing Records

Maintain an inventory of personal data, systems, repositories, models, agents, flows, purposes, owners, retention, recipients, and transfer locations. Classification and lineage should allow the organisation to trace how personal data enters, changes, feeds AI systems, generates derived data, and leaves the environment.

Use data inventories, lineage diagrams, processing records, system ownership, classification evidence, and periodic reconciliation as core audit artifacts.

Chapter 16 — Privacy by Design and Data-Protection Impact Assessment

Integrate privacy considerations into product, system, AI, procurement, and change lifecycles before deployment. Use proportionate impact assessment for higher-risk processing, new technologies, sensitive data, automated decisions, large-scale processing, or material changes.

Evidence should capture identified risks, affected individuals, data flows, controls, residual risk, approvals, consultations, and post-implementation review.

Chapter 17 — AI Use-Case Intake and Risk Classification

Require every material AI use case to enter a controlled inventory before production. Record purpose, users, affected individuals, data types, model or agent characteristics, third parties, autonomy, decision significance, privacy impact, security exposure, and regulatory overlays.

Maintain an AI use-case register, risk tier, accountable owner, approval status, required controls, and review cadence.

Chapter 18 — Traditional AI Governance Framework Implementation

Use Singapore's Traditional AI Model Governance Framework as voluntary implementation guidance for internal governance, human involvement, operations management, and stakeholder communication. Translate its principles into organisation-specific controls without presenting the framework as a statutory certification scheme.

Evidence may include governance roles, model documentation, human-review design, operational controls, explanations, communications, and monitoring results.

Chapter 19 — Generative AI Governance Framework Implementation

Apply the Generative AI governance framework across accountability, data, trusted development and deployment, incident reporting, testing and assurance, security, provenance, safety and alignment, and broader ecosystem considerations as relevant to the use case. Distinguish organisational commitments from legal obligations.

Maintain GenAI risk assessments, model/system cards, data provenance, evaluation plans, safety and security testing, incident records, user guidance, and assurance evidence.

Chapter 20 — Agentic AI Governance Framework Implementation

For agentic systems, assess and bound autonomy, tool and data access, transaction authority, persistence, delegation, and environmental impact before deployment. Define meaningful human approval checkpoints, lifecycle controls, monitoring, transparency, training, third-party-agent governance, multi-agent risk treatment, and automation-bias safeguards consistent with current IMDA guidance.

Evidence should include agent inventories, authority boundaries, approval gates, tool-access matrices, testing, monitoring, incident records, and owner accountability.

Chapter 21 — Human Accountability, Approval Checkpoints, and Meaningful Oversight

Assign named humans or governance bodies accountable for consequential AI outcomes. Human oversight should have sufficient information, authority, competence, time, and system capability to intervene; nominal review or rubber-stamping is not meaningful control.

Maintain decision-right matrices, checkpoint designs, escalation thresholds, reviewer competence evidence, override logs, and effectiveness testing.

Chapter 22 — AI Data Governance, Provenance, Quality, and Minimisation

Govern training, retrieval, evaluation, prompt, fine-tuning, telemetry, and agent-memory data through documented provenance, permitted-use, quality, minimisation, access, retention, and transfer controls. Derived or synthetic data should not be assumed outside privacy or confidentiality obligations without analysis.

Evidence should include dataset registers, provenance records, licences/permissions, quality checks, minimisation decisions, lineage, access reviews, and deletion controls.

Chapter 23 — Fairness, Bias, Explainability, Transparency, and Contestability

Identify fairness and bias risks appropriate to context and affected groups, define explanation needs, communicate AI involvement appropriately, and provide review or contestability mechanisms where warranted by risk, law, contract, or organisational commitment. Avoid universal fairness metrics that ignore use-case context.

Maintain fairness assessments, test results, explanation artifacts, notices, feedback channels, contest records, and remediation decisions.

Chapter 24 — AI Security, Robustness, Testing, and Lifecycle Controls

Integrate AI systems into secure development, change management, model and dependency governance, access control, secrets management, logging, evaluation, robustness testing, incident response, and retirement. Higher autonomy should lead to stronger control over privileges, external actions, monitoring, and failure containment.

Evidence should include threat/risk assessments, secure-build records, evaluation suites, change approvals, monitoring results, incident findings, and retirement evidence.

Chapter 25 — AI Verify and Assurance/Testing Evidence Boundaries

Use AI Verify and related assurance resources as voluntary testing and evidence mechanisms where useful. Test results should be scoped to the system, version, data, configuration, benchmark, and date assessed and must not be represented as universal proof of safety, legality, or regulatory approval.

Maintain test plans, tool versions, datasets, thresholds, results, limitations, remediation, and assurance sign-off.

Chapter 26 — Third-Party Models, Agents, Processors, and Supply-Chain Governance

Perform risk-based due diligence for model providers, hosted AI, data processors, agent platforms, plugins, tools, and critical dependencies. Contracts and technical controls should address data handling, confidentiality, security, subprocessors, changes, incidents, retention, transfers, audit evidence, continuity, and exit.

Maintain supplier inventories, assessments, contracts, dependency records, monitoring, exceptions, incident evidence, and exit plans.

Chapter 27 — Multi-Agent Systems, Tool Access, and Bounded Authority Governance

For multi-agent or tool-using environments, document allowed interactions, authority limits, handoffs, shared context, external services, and approval boundaries. Prevent uncontrolled privilege accumulation by ensuring each agent receives only the data, tools, credentials, and actions necessary for its approved purpose.

Evidence should include agent interaction maps, tool allowlists, credential design, delegation rules, approval checkpoints, test results, and monitoring records.

Chapter 28 — Stakeholder Communications, Notices, Feedback, and Responsible Use

Communicate material AI involvement, purpose, limitations, user responsibilities, escalation options, and privacy information in a form appropriate to the audience and risk. Internal

training should address over-reliance, confidentiality, data entry, approval responsibilities, and when human review is mandatory.

Maintain notices, user guidance, training completion, feedback channels, complaint records, communications testing, and updates after material system changes.

Chapter 29 — Incident, Privacy-Breach, and AI-Harm Escalation Integration

Integrate AI incidents with cybersecurity, privacy, operational risk, legal, communications, and executive escalation. Distinguish a security event, personal-data breach, model-quality defect, harmful output, control failure, and regulatory-reporting trigger rather than assuming one severity scale answers every obligation.

Maintain incident classification, facts, legal/privacy assessments, containment, notification decisions, stakeholder communications, root-cause analysis, and corrective actions.

Chapter 30 — Monitoring, Metrics, Enforcement Learnings, and Continuous Improvement

Monitor privacy operations and AI controls using metrics that reveal effectiveness, not just activity. Review PDPC enforcement lessons and IMDA governance updates for control implications while avoiding unsupported extrapolation from fact-specific enforcement matters.

Maintain dashboards, threshold definitions, trend analysis, enforcement-learning records, management review, improvement actions, and evidence of closure.

Chapter 31 — Evidence Architecture, Auditability, and Crosswalk Governance

Design evidence so an auditor can trace each requirement or governance commitment to owner, control, operation, test, exception, and remediation. Crosswalks to other frameworks may show relationships but must not claim legal or control equivalence without supported analysis.

Maintain evidence indexes, control maps, crosswalk rationale, ownership, version history, sampling results, exceptions, and audit findings.

Chapter 32 — Release-Time Legal/Framework Change Control and Implementation Roadmap

Immediately before release, reverify PDPA/PDPC requirements, Data Portability status, breach-notification facts, current Traditional/Generative/Agentic AI framework status, AI Verify resources, and material sector overlays. Any material change after candidate freeze requires explicit impact assessment and, where necessary, a superseding candidate with new provenance.

The implementation roadmap should assign owners, priorities, dependencies, evidence targets, milestones, review cadence, management approvals, and continual-improvement actions while preserving the distinction between legal duties and voluntary governance commitments.